🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 07: Exploiting Broken Function Level Authorization (BFLA) Flaws to Manipulate API Reques
```

Scenario

Broken Function Level Authorization (**BFLA**) occurs when an API application fails to enforce granular role-based access control (RBAC) at administrative or sensitive function endpoints. Developers frequently restrict administrative user interface buttons, but rely solely on client-side controls without enforcing server-side authorization checks on administrative API routes or HTTP verbs.

In **OWASP crAPI**, regular users can update personal profile video titles via `PUT` requests to `/identity/api/v2/user/videos/<id>`. By issuing an **OPTIONS** request, attackers can enumerate allowed HTTP methods (discovering **5** permitted verbs). Changing the HTTP method to **DELETE** and altering the URI path to the administrative namespace (**/identity/api/v2/admin/videos/**) allows non-privileged users to invoke administrative endpoints and delete any target user's uploaded videos (**/identity/api/v2/admin/videos/5**).

In this exercise, we log into crAPI on Parrot Security, capture video modification requests in Burp Suite, test permitted HTTP verbs using **OPTIONS** (**5** allowed methods), escalate API routing privileges to admin paths, and execute BFLA video deletion attacks against arbitrary user resource IDs.

Objective

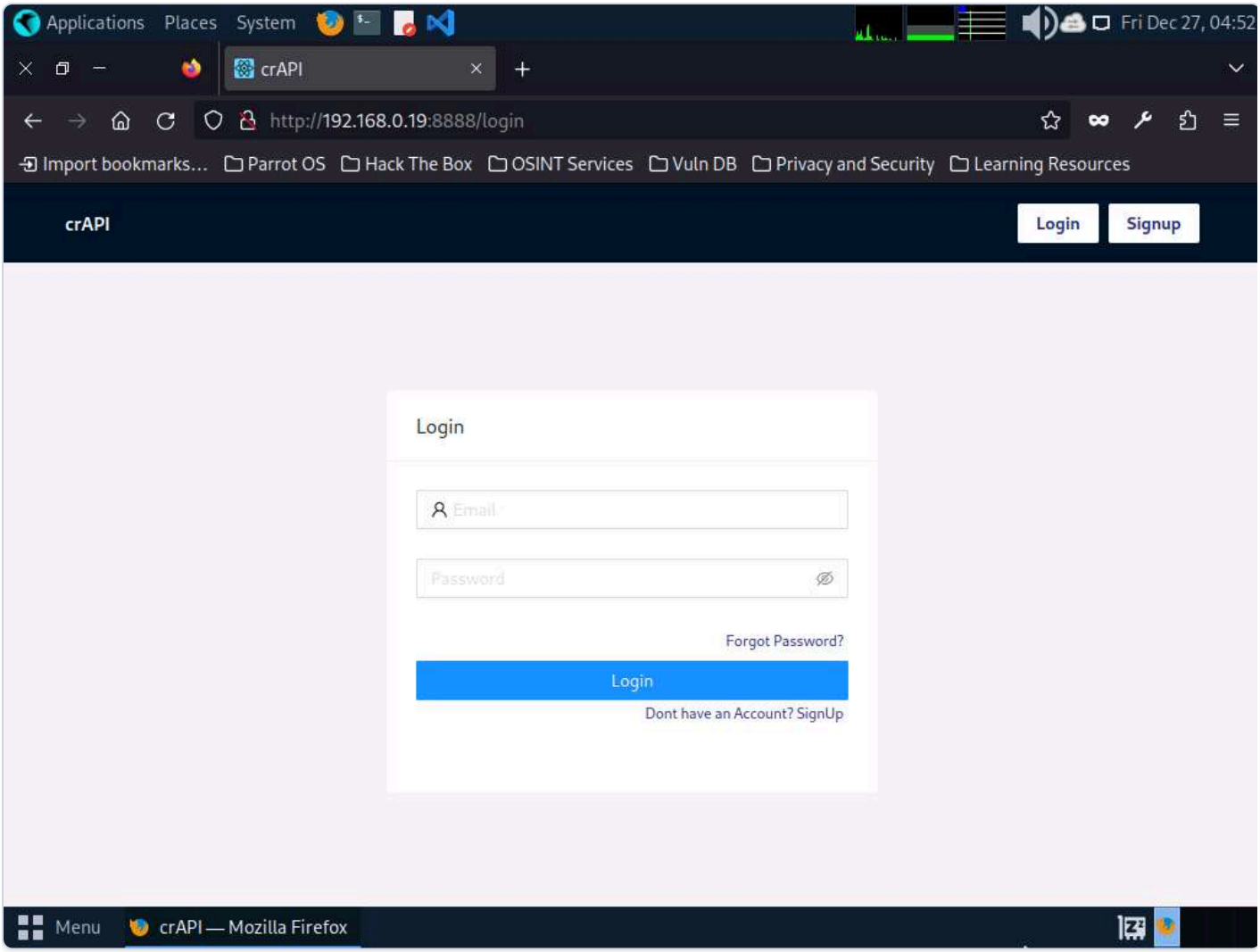
The objective of this lab is to help students learn how to:
- Intercept and manipulate REST API HTTP request methods in Burp Suite Repeater
- Enumerate supported server HTTP verbs using **OPTIONS** requests (**5** permitted methods)
- Identify administrative API endpoints and path structures (**/identity/api/v2/admin/videos/**)
- Exploit Broken Function Level Authorization (BFLA) flaws to execute administrative functions without admin privileges
- Combine BFLA with resource ID manipulation to alter or delete victim resources (**/identity/api/v2/admin/videos/5**)

Task 1: Exploit BFLA and Manipulate Administrative API Requests

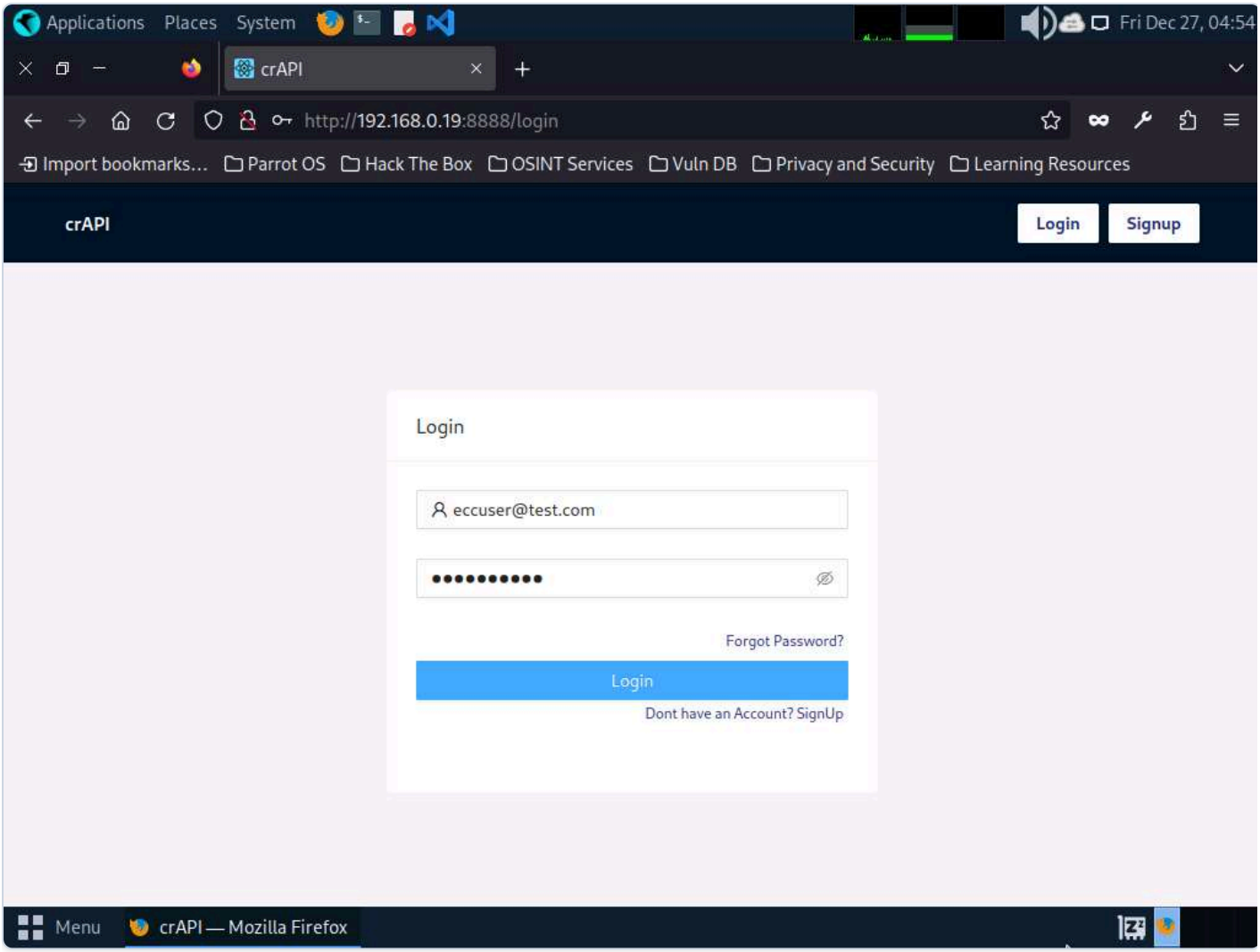
In this task, we log into crAPI on Parrot Security, upload video assets, capture `PUT` request parameters in Burp Suite, discover supported HTTP methods via `OPTIONS`, escalate route paths to `/identity/api/v2/admin/`, and delete victim user video assets using `DELETE`.

Lab Tasks

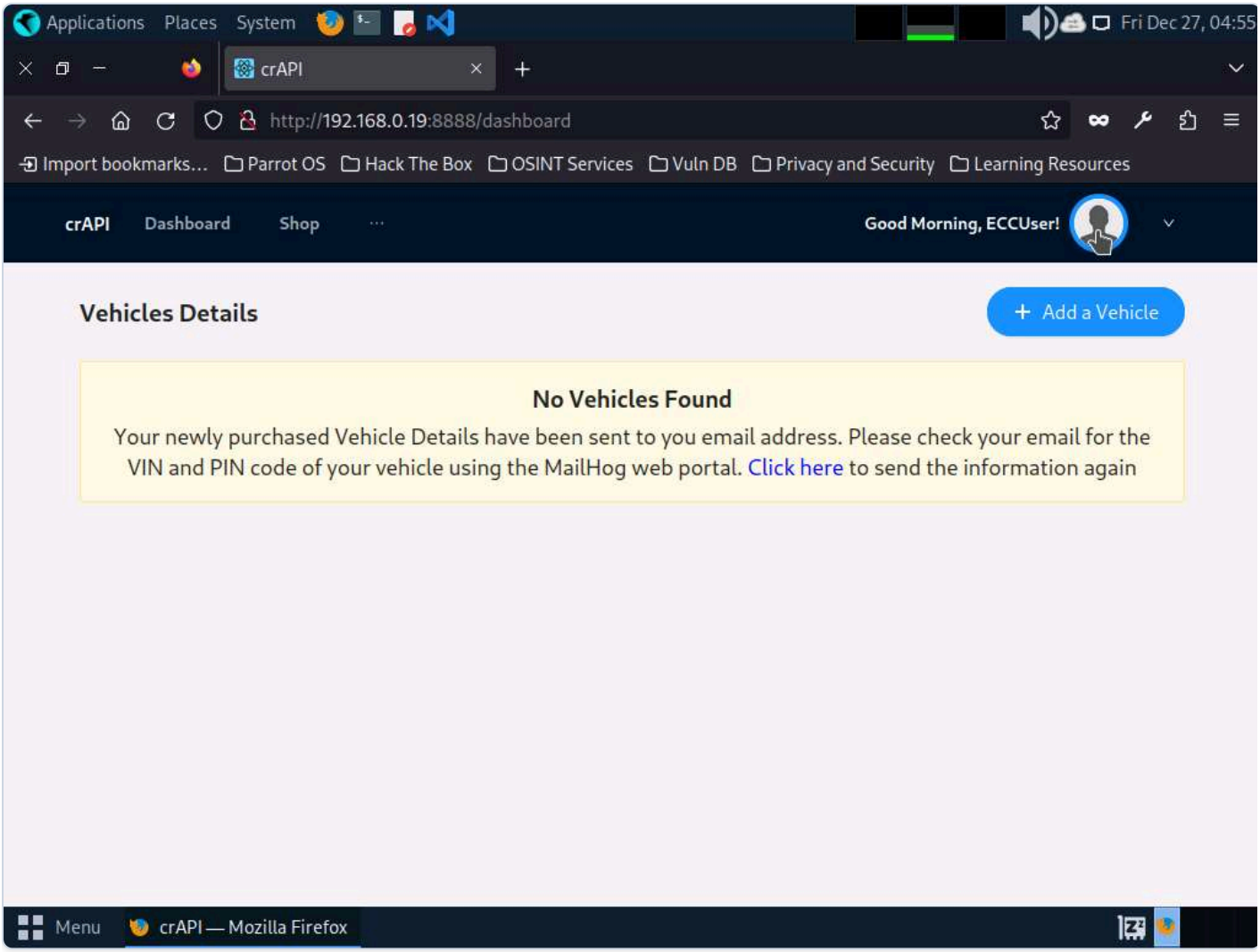
1. Switch to **Parrot Security** (**pentester** / **toor**). Open Firefox and navigate to **http://192.168.0.19:8888/**.



1. Log into your crAPI account.

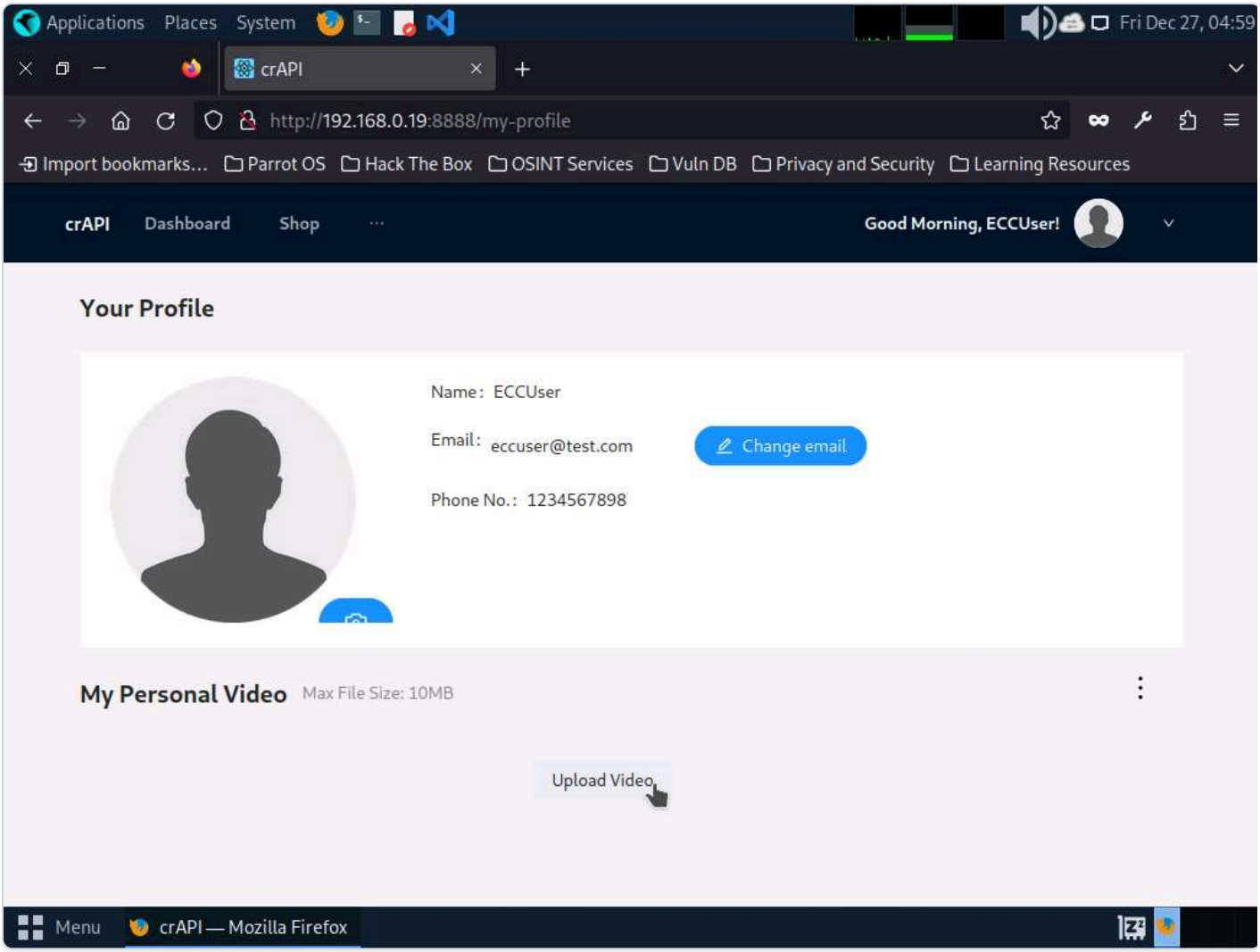


1. Click the profile icon in the upper right menu.



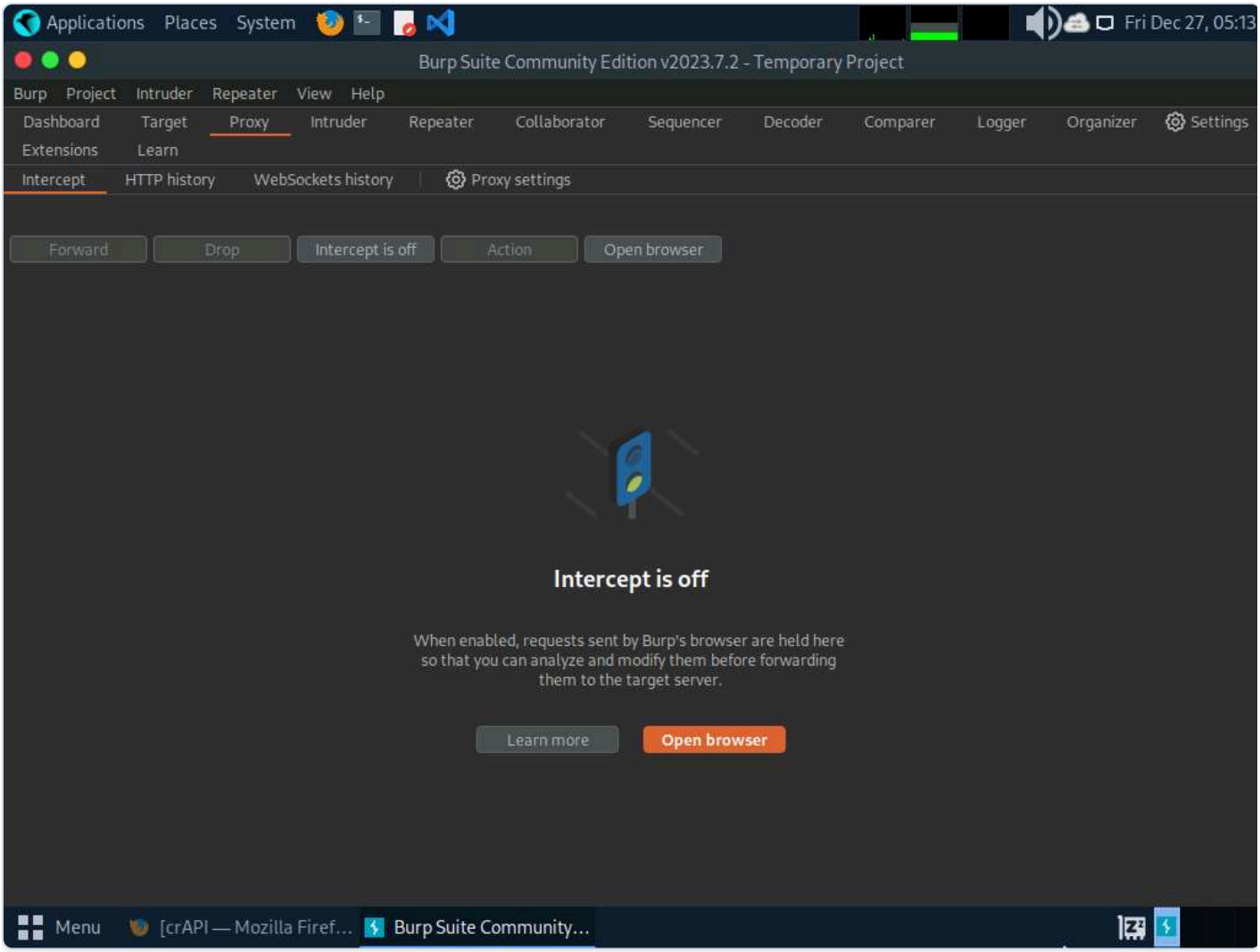
1. Under **My Personal Video**, hover over the video icon and click **Upload Video**.

1. Select an `.mp4` video file, click **Open**, and confirm the upload confirmation.
2. Launch **Burp Suite Community Edition** on Parrot Security. Go to **Proxy** tab, set **Intercept is OFF**, and click **Open browser**.

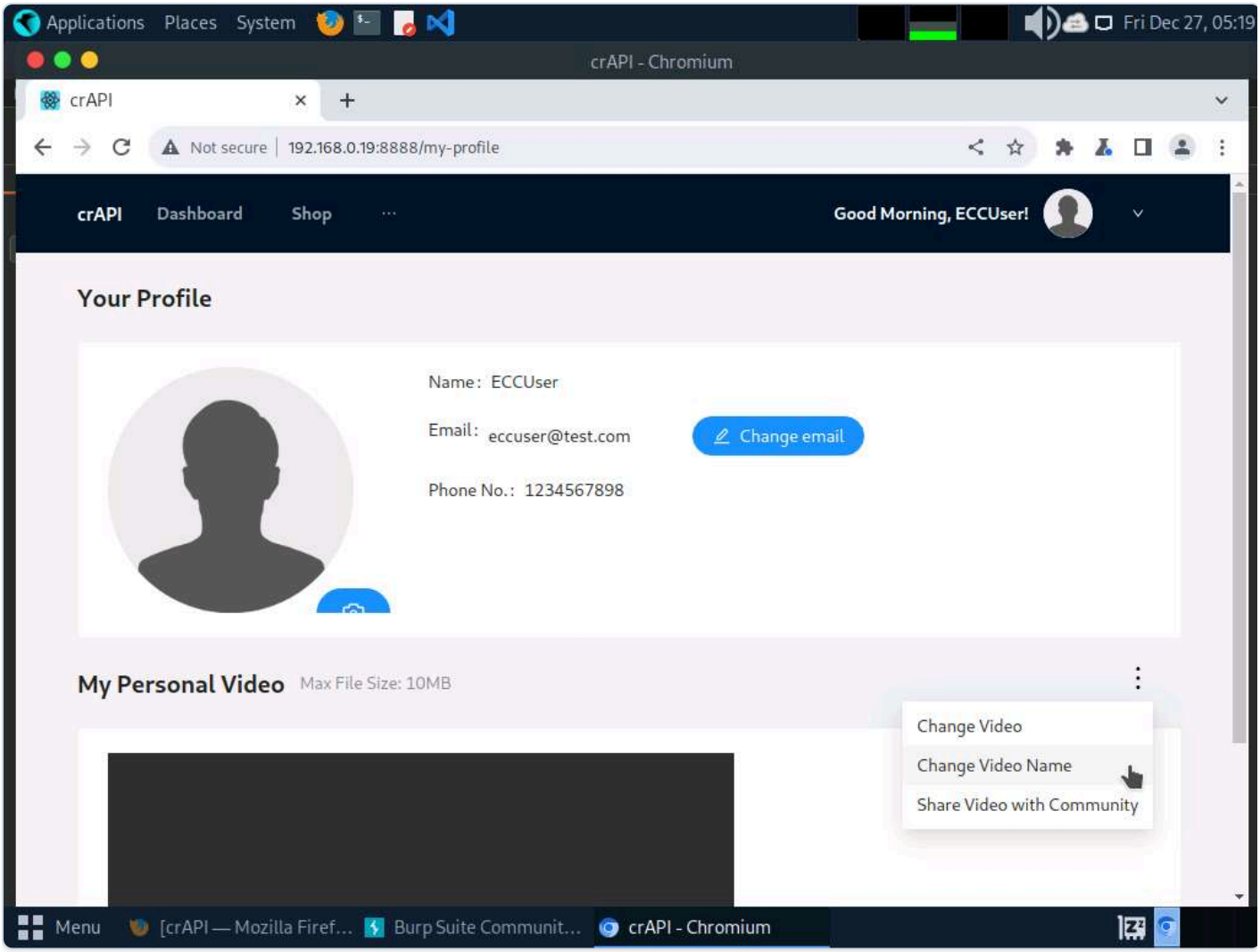


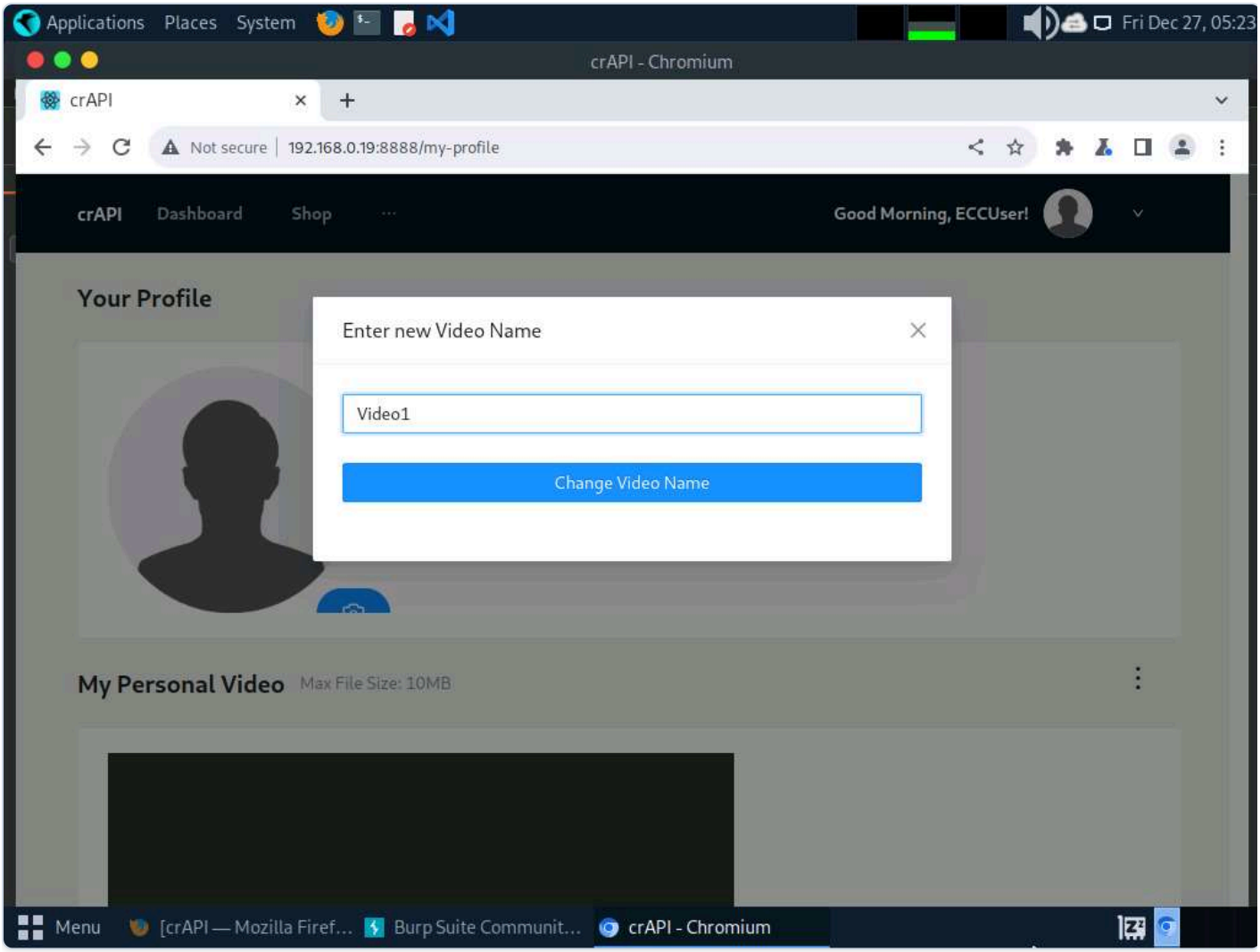
1. In the Burp Chromium Browser, navigate to **http://192.168.0.19:8888** and log into your account.

2. Go to your Profile page, locate **My Personal Video**, and click **Change Video Name**.

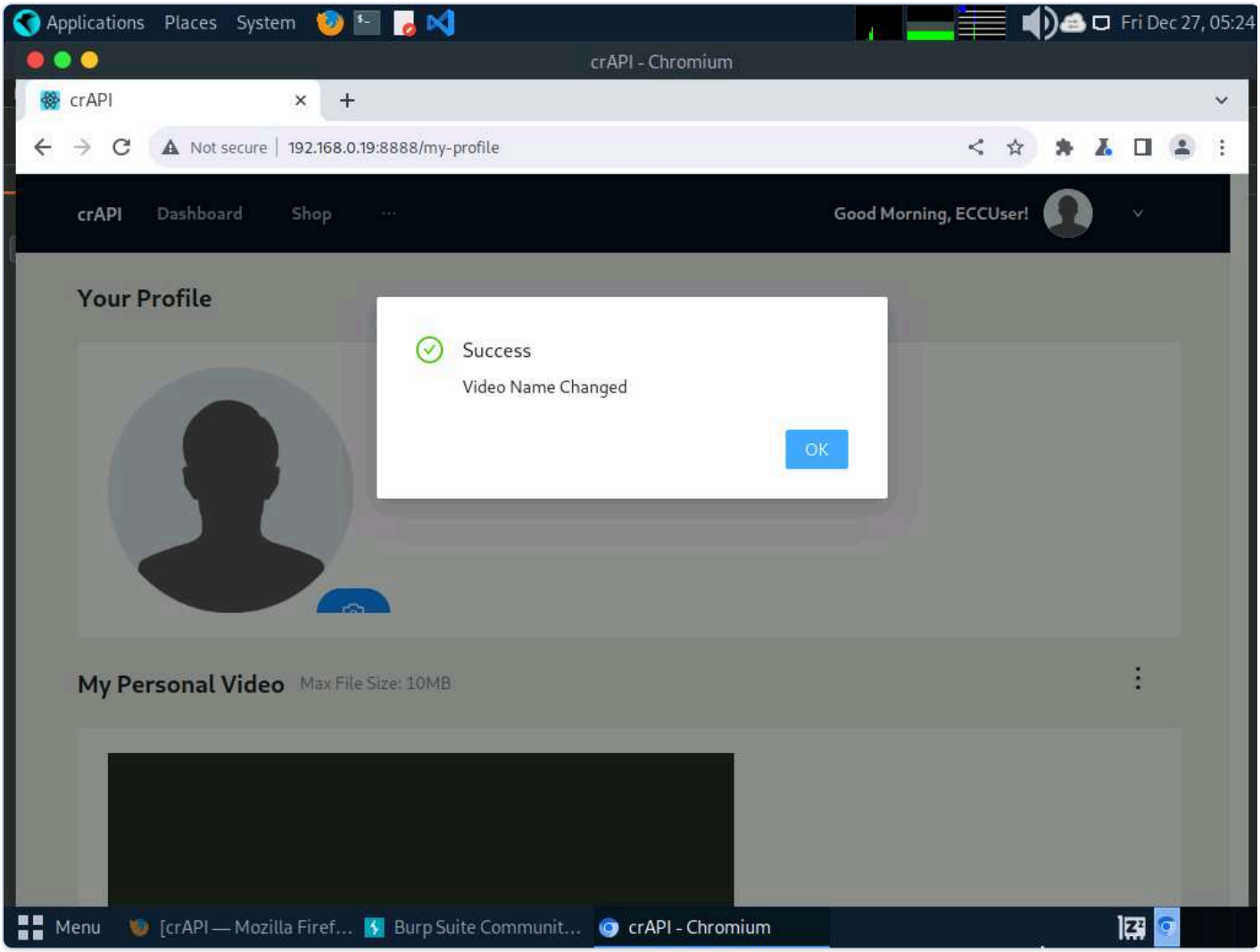


1. Enter `Video1` into the new video name dialog and click **Change Video Name**. Click **OK**.

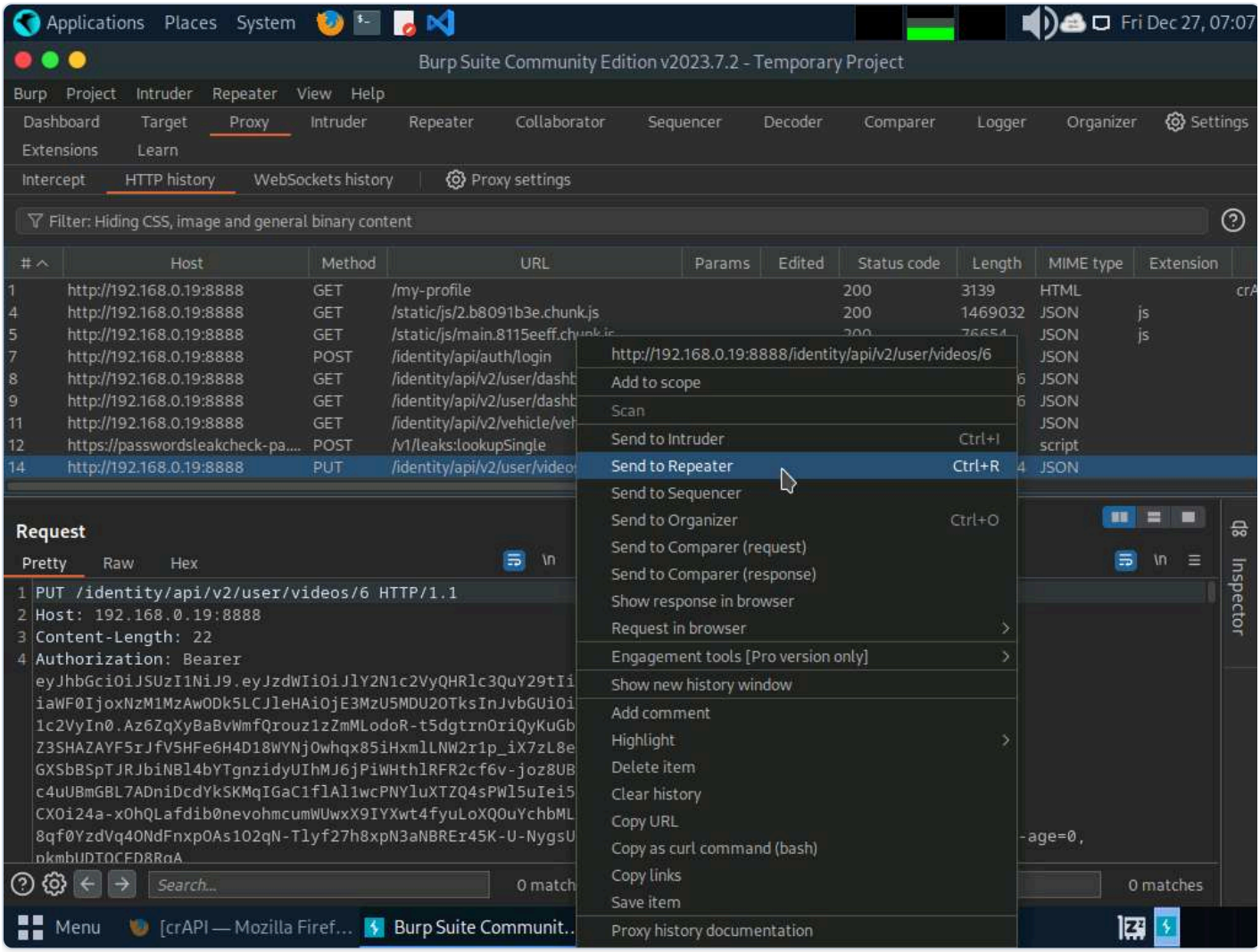

Applications
Places
System
Fri Dec 27, 05:19
crAPI - Chromium
crAPI
Not secure
192.168.0.19:8888/my-profile
crAPI
Dashboard
Shop
Good Morning, ECCUser!
Your Profile
Name: ECCUser
Email: eccuser@test.com
Change email
Phone No.: 1234567898
My Personal Video
Max File Size: 10MB
Change Video
Change Video Name
Share Video with Community
Menu
[crAPI — Mozilla Firef...
Burp Suite Communit...
crAPI - Chromium

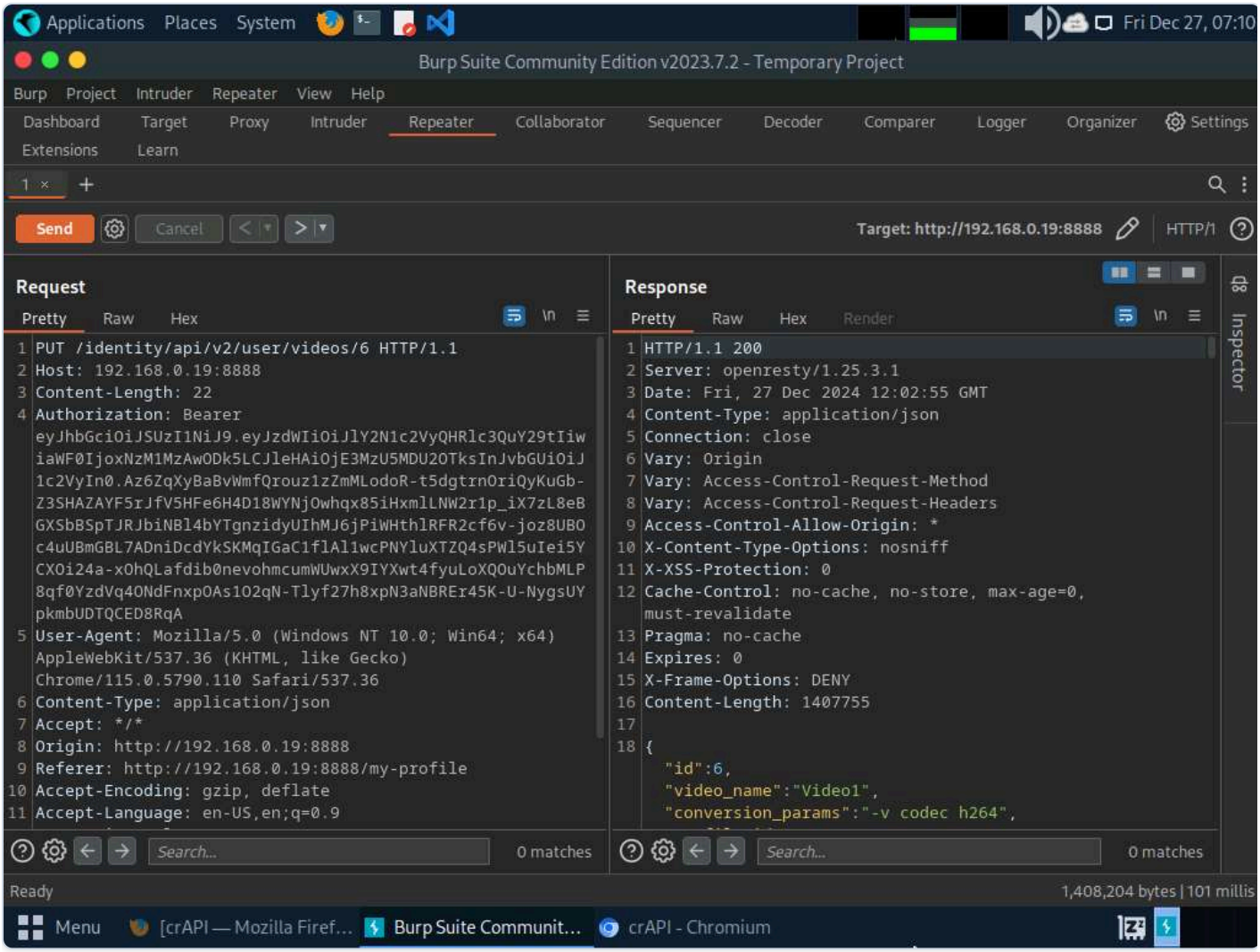


1. Switch to Burp Suite, open **Proxy** $
   ightarrow$ **HTTP history**, locate the **PUT** video rename request, right-click, and select **Send to Repeater**.



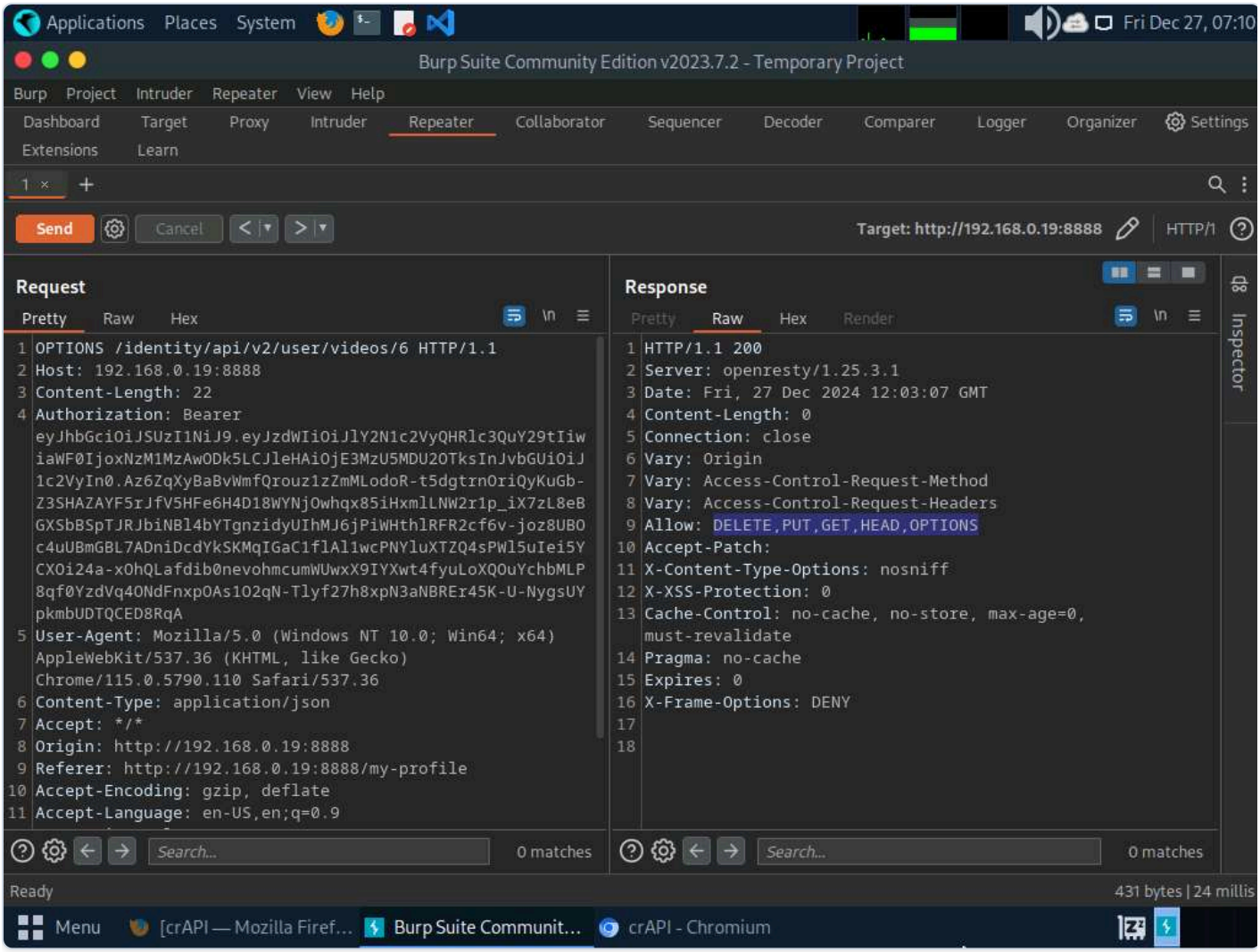
1. In the Repeater tab, change the HTTP verb from **PUT** to **OPTIONS** to inspect supported server methods. Click **Send**.


Applications Places System
Fri Dec 27, 07:07
Burp Suite Community Edition v2023.7.2 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
Intercept HTTP history WebSockets history Proxy settings
Filter: Hiding CSS, image and general binary content
Host Method URL Params Edited Status code Length MIME type Extension
1 http://192.168.0.19:8888 GET /my-profile 200 3139 HTML
4 http://192.168.0.19:8888 GET /static/js/2.b8091b3e.chunk.js 200 1469032 JSON js
5 http://192.168.0.19:8888 GET /static/js/main.8115eeff.chunk.js JSON js
7 http://192.168.0.19:8888 POST /identity/api/auth/login JSON
8 http://192.168.0.19:8888 GET /identity/api/v2/user/dashb JSON
9 http://192.168.0.19:8888 GET /identity/api/v2/user/dashb JSON
11 http://192.168.0.19:8888 GET /identity/api/v2/vehicle/veh JSON
12 https://passwordsleakcheck-pa.... POST /v1/leaks:lookupSingle script
14 http://192.168.0.19:8888 PUT /identity/api/v2/user/video JSON
http://192.168.0.19:8888/identity/api/v2/user/videos/6
Add to scope
Scan
Send to Intruder Ctrl+I
Send to Repeater Ctrl+R
Send to Sequencer
Send to Organizer Ctrl+O
Send to Comparer (request)
Send to Comparer (response)
Show response in browser
Request in browser
Engagement tools [Pro version only]
Show new history window
Add comment
Highlight
Delete item
Clear history
Copy URL
Copy as curl command (bash)
Copy links
Save item
Proxy history documentation
Request
Pretty Raw Hex
1 PUT /identity/api/v2/user/videos/6 HTTP/1.1
2 Host: 192.168.0.19:8888
3 Content-Length: 22
4 Authorization: Bearer
eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJlY2N1c2VyQHRlc3QuY29tIi
iaWF0IjoxNzM1MzAwODk5LCJleHAiOjE3MzU5MDU2OTksInJvbGUiOi
1c2VyIn0.Az6ZqXyBaBvWmfQrouz1zZmMLodoR-t5dgtrnOriQyKuGb
Z3SHAZAYF5rJfV5HFe6H4D18WYNjOwhqx85iHxmlLNW2r1p_iX7zL8e
GXSbBSpTJRJbiNBl4bYTgnzidyUIhMJ6jPiWHthlRFR2cf6v-joz8UB
c4uUBmGBL7ADniDcdYkSKMqIGaC1flAl1wcPNYluXTZQ4sPWl5uIei5
CXOi24a-xOhQLafdib0nevohmcumWUwxX9IYXwt4fyuLoXQOuYchbML
8qf0YzdVq4ONdFnxpOAs1O2qN-Tlyf27h8xpN3aNBREr45K-U-NygsU
pkmbUDTQCED8RqA
-age=0,
Search...
0 match
0 matches
Inspector
Menu
[crAPI — Mozilla Firef...
Burp Suite Communit...

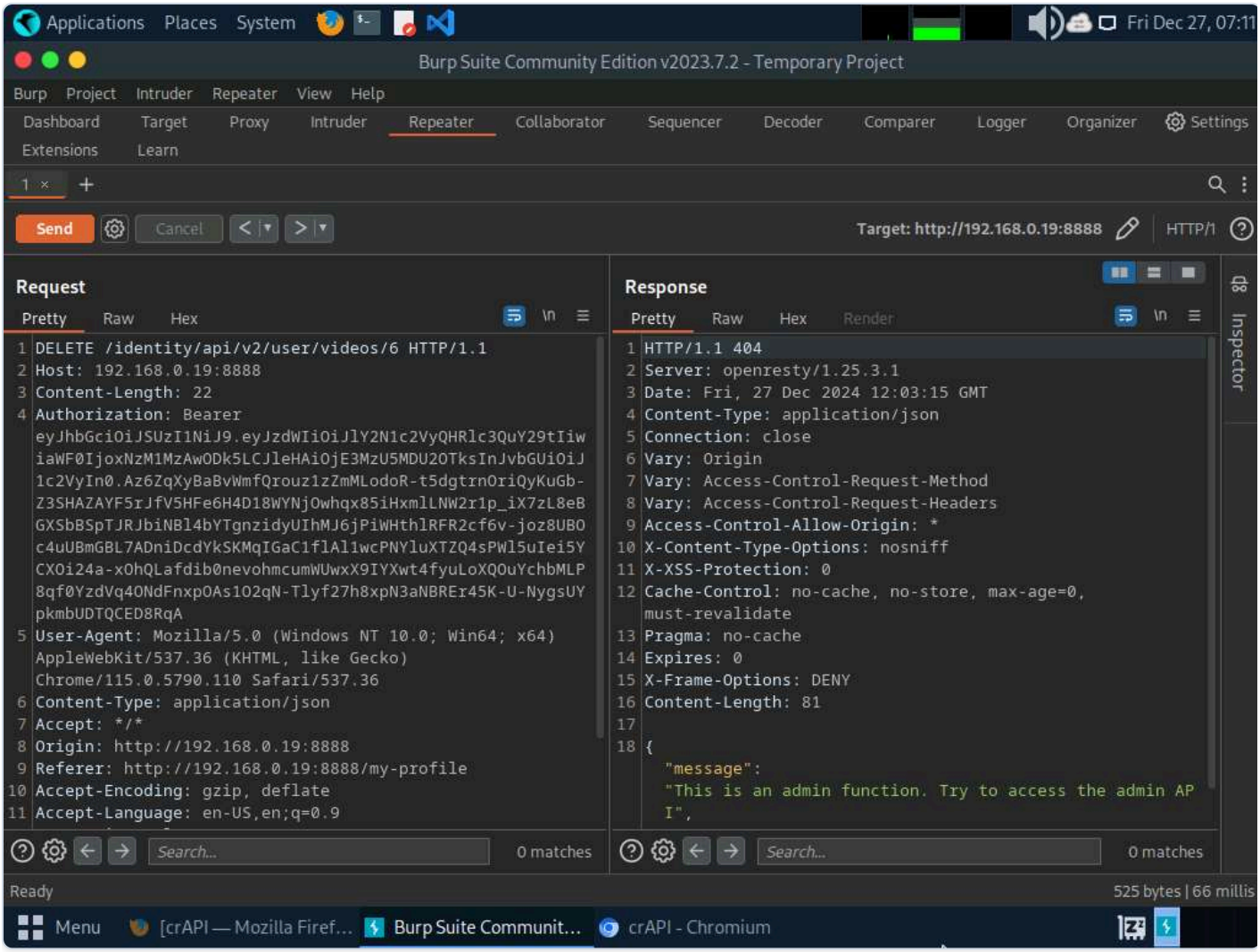


1. Note that the server response headers indicate **5** permitted HTTP methods (`GET, HEAD, POST, PUT, DELETE, OPTIONS`).

2. Change the HTTP request method to **DELETE** with an empty body and click **Send**. The server returns an administrative guidance message: "*This is an admin function. Try to access the admin API.*"

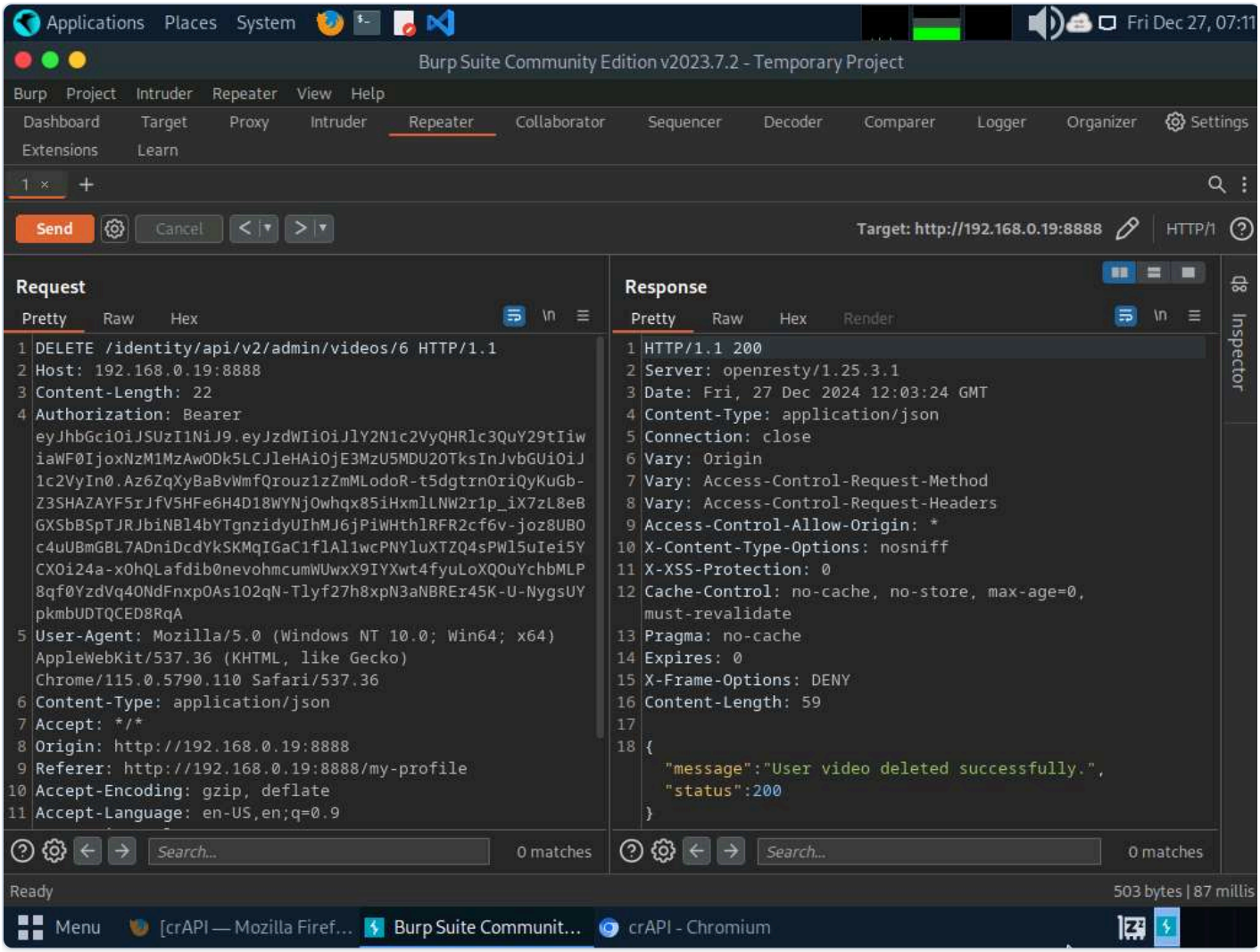


1. Alter the request endpoint path from `/identity/api/v2/user/videos/` to **/identity/api/v2/admin/videos/** and click **Send**.

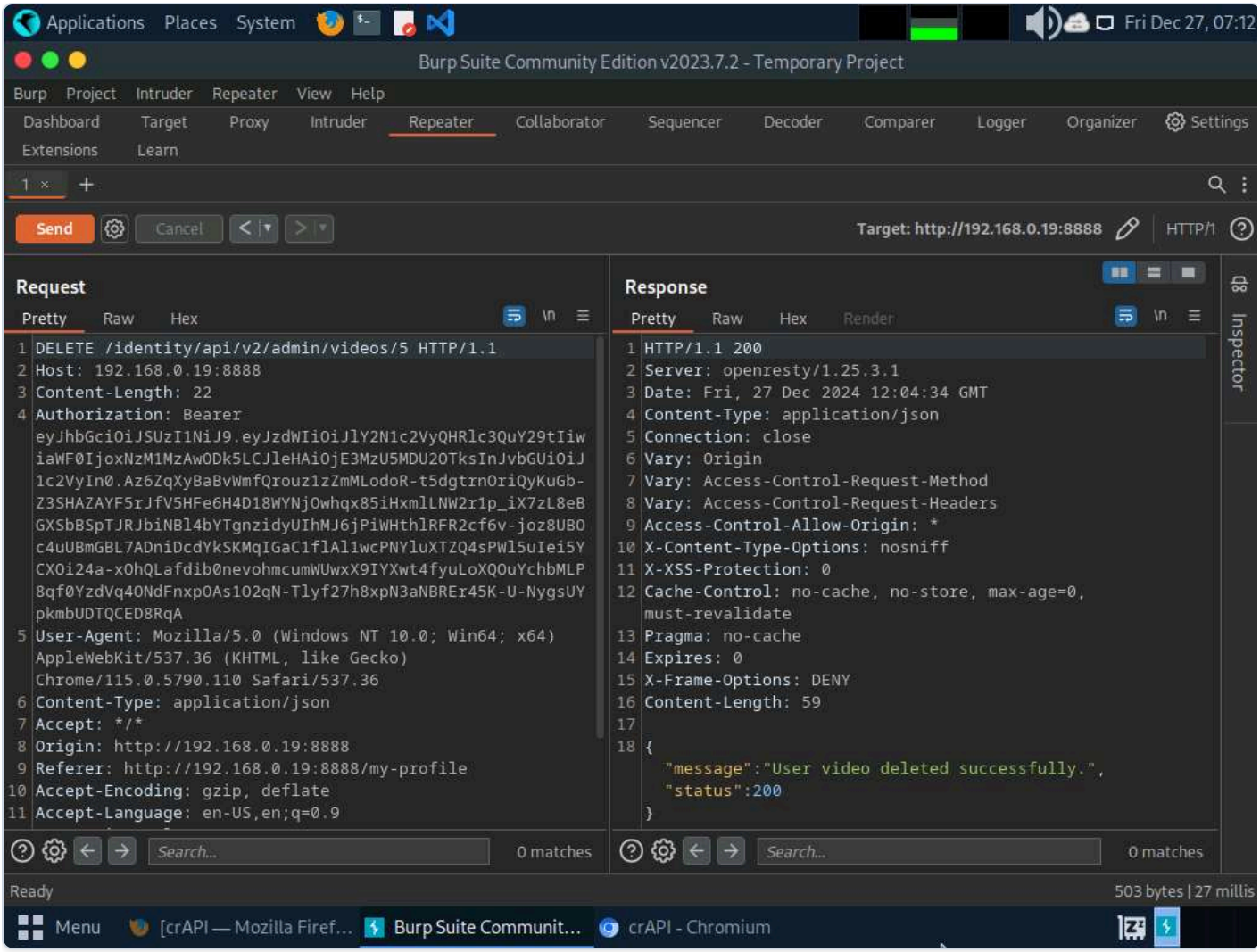


1. Confirm that the server processes the administrative deletion request using the standard user token, successfully deleting your video asset.

2. Exploit BFLA further by changing the video resource ID at the end of the URL to a victim user's ID: **/identity/api/v2/admin/videos/5**



1. Click **Send** and confirm HTTP 200 OK response, proving unauthorized deletion of victim resource ID 5.



1. Close all browser and Burp Suite windows.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 6.7.1.1** Using a Parrot Security machine, access crAPI and utilize Burp Suite to identify and exploit Broken Function Level Authorization (BFLA) vulnerabilities. This involves analyzing and manipulating API requests to gain unauthorized access to restricted functions or sensitive data. Determine the number of HTTP methods permitted in crAPI within this lab environment. [!SUCCESS] ✅ **Answer:** **5**